

Лабораторна робота №3. Дослідження безпечної реалізації та експлуатації децентралізованих додатків

ФБ-51мн Подолянко Тимофій

Огляд OWASP ASVS

[OWASP \(Open Worldwide Application Security Project\) ASVS \(Application Security Verification Standard\)](#)

описує вимоги до безпеки веб-застосунків та сервісів. В роботі розглядається остання на момент виконання версія 5.0.0 OWASP ASVS.

Визначення застосунку (application) в рамках Стандарту є достатньо гнучким, що дозволяє застосовувати положення Стандарту не тільки до традиційних web-застосунків:

ASVS defines an “application” as the software product being developed, into which security controls must be integrated. ASVS does not prescribe development lifecycle activities or dictate how the application should be built via a CI/CD pipeline; instead, it specifies the security outcomes that must be achieved within the product itself.

ASVS включає близько 250 вимог розділених на 17 частин. Частини і секції впорядковані таким чином, щоб "спростити вибір та фільтрування частин і секцій зважаючи на те, що є доречним для застосунку".

Варто зазначити, що ASVS визначає три рівні вимог до застосунків відповідно до їх рівня ризику. Обрання рівня відповідності покладається на організацію-власника застосунку. Можна стверджувати, що застосунки у сфері децентралізованих фінансів мають прагнути до виконання третього рівня вимог, тобто всіх вимог стандарту. Окрім об'єктивної оцінки рівня безпеки застосунку, відповідність більш високому рівню ASVS сприяє підвищенню репутації організації.

Складання вимог для системи децентралізованих додатків Ethereum.

Розглянемо можливість складання аналогічної системи вимог для децентралізованих додатків Ethereum (смарт-контрактів).

Поточна версія ASVS включає "приблизно 350 вимог", поділених у 17 розділів. Для адаптації ASVS до децентралізованих застосунків, як це запропоновано у Стандарті, виключимо нерелевантні розділи. Зауважимо, що ці розділи все ж матимуть актуальність для окремих компонентів децентралізованого додатку, наприклад, веб-інтерфейсу користувача за його наявності.

Наступні розділи надалі не розглядатимемо:

- **V3 Web Frontend Security** - безпека веб-фронтенду застосунку. Безумовно, веб-фронетнд є складовою значної частини розподілених додатків, але вимоги цього розділу не є актуальними до on-chain застосунків Ethereum.
- **V4 API and Web Service** - вимоги цього розділу сфокусовані на конкретних веб-технологіях, що не мають відношення до розподілених застосунків на блокчейні.
- **V5 File Handling** - не актуально для смарт-контрактів Ethereum.

- **V6 Authentication** - проблема автентифікації делегується блокчейну, тому всі операції на блокчейні є автентифікованими.
- **V7 Session Management** - залежно від реалізації розподіленого застосунку, в ньому може бути виконане керування сесіями в розумінні, схожому до на сесії у веб-застосунках. Але у поточній версії ASVS вимоги цього розділу стосуються поняття сесії, яке не є застосовним до розподілених застосунків на блокчейні.
- **V10 OAuth and OIDC** - ці протоколи не мають аналогів на блокчейні Ethereum
- **V12 Secure Communication** - у блокчейнах транзакції передаються у відкритому вигляді та є підписаними відправником, що позбавляє від необхідності додаткового захисту каналів зв'язу.
- **V14 Data Protection** - вимоги цього розділу також втрачають актуальність через властивості блокчейну.
- **V17 WebRTC** - не актуально для смарт-контрактів Ethereum.

Таким чином, для розгляду залишається 8 розділів. Розглянемо їх більш детально.

V1 Encoding and Sanitization

Розподілені додатки можуть виконувати обчислення над наданою користувачами інформацією, тому проблема кодування та санітизації дани залишаються для них актуальними, зокрема, загальні 1.1.1 та 1.1.2. Вимоги V1.2, V1.3, V1.5 в поточній версії не містять вимог, застосовних до розподілених застосунків. Вимоги 1.4.1, 1.4.2, 1.4.3 мають враховуватися залежні від реалізації смарт-контракту.

V2 Validation and Business Logic

Цей розділ містить вимоги, які в поточній формі вже можливо застосувати до розподілених додатків. Зокрема, за визначенням вимоги 2.3.1 покриває навіть вразливості типу reentrancy, які входять у [OWASP Smart Contract Top 10-2025](#).

Вимоги V2.4 Anti-automation не є актуальними.

V8 Authorization

Вимоги розділу є актуальними, залежно від конкретної реалізації смарт-контракту.

V9 Self-contained Tokens

Вимоги розділу можуть бути актуальними, залежно від конкретної реалізації смарт-контракту.

V11 Cryptography

Вимоги розділу є актуальними, залежно від конкретної реалізації смарт-контракту.

V13 Configuration

Необхідно аналізувати окремі вимоги. Наприклад, 13.1.1 можна поширити на взаємодію із сторонніми смарт-контрактами. Натомість, 13.1.2 не є актуальним оскільки навантаження на блокчейні не припадає на деякий конкретний екземпляр застосунку, а розподіляється по мережі.

V15 Secure Coding and Architecture

Вимоги розділу є значною мірою актуальними для смарт-контрактів Ethereum. ASVS V15 охоплює безпечне проєктування архітектури, управління залежностями та уникнення небезпечних конструкцій — усе це має прямі аналоги у Solidity-розробці.

Вимоги щодо управління залежностями (V15.1) є повністю застосовними: використання неаудійованих або застарілих бібліотек є типовим вектором атаки. Рекомендованою практикою вважається використання добре відомих бібліотек на зразок OpenZeppelin замість власних реалізацій криптографічних примітивів чи механізмів контролю доступу.

Вимоги щодо безпечної архітектури (V15.2) потребують адаптації. Принцип мінімальної поверхні атаки відповідає рекомендації тримати смарт-контракти якомога простішими. Патерни оновлюваності (проху-контракти — transparent proxy, UUPS) вимагають особливої уваги, оскільки вони суттєво розширюють поверхню атаки та вводять додаткові ризики, наприклад, підміну реалізації або помилки ініціалізації.

Вимоги щодо небезпечних конструкцій (V15.3) мають безпосередні відповідники в Ethereum-розробці:

- використання tx.origin для авторизації замість msg.sender є відомою вразливістю;
- покладання на block.timestamp або blockhash як на джерело ентропії є небезпечним, оскільки ці значення можуть частково контролюватися валідаторами;
- використання низькорівневих викликів (call, delegatecall, staticcall) без належної перевірки повернутого значення призводить до мовчазних відмов;
- використання delegatecall до зовнішніх, потенційно ненадійних контрактів є особливо критичним.

Вимоги щодо безпеки пам'яті (V15.4), орієнтовані переважно на мови з ручним керуванням пам'яттю, є малоактуальними для Solidity, але частково застосовуються при написанні inline-assembly (assembly блоків у Yul), яке слід використовувати лише у виправданих випадках.

V16 Security Logging and Error Handling

Через прозорість операцій на блокчейні вимоги щодо логування можна опустити. При цьому, V16.5 Error Handling мають бути задоволені.

ВИСНОВКИ

Проведений аналіз показує, що часткове перенесення вимог OWASP ASVS до розподілених застосунків на базі блокчейна Ethereum є можливим і доцільним. Зі 17 розділів стандарту 8 містять вимоги, що залишаються актуальними повністю або після адаптації з урахуванням особливостей Ethereum.

Разом з тим, специфіка технології блокчейн вимагає окремого підходу до тестування безпеки — ASVS як такий не охоплює клас вразливостей, характерних виключно або переважно для смарт-контрактів. До таких вразливостей належать:

- Reentrancy - попри те що вимога 2.3.1 може бути інтерпретована так, щоб покрити цю вразливість, безпосередньо в ASVS вона не фігурує;
- Маніпуляція оракулами та ціновими джерелами — підміна або спотворення зовнішніх даних, що надходять до смарт-контракту через оракули (наприклад, Chainlink, Uniswap TWAP), яка може призвести до некоректних обчислень та фінансових втрат;
- Flash-loan атаки — використання незабезпечених миттєвих позик для маніпуляцій станом протоколу в межах однієї транзакції;

- MEV (Miner/Maximal Extractable Value) та front-running — можливість валідаторів або інших учасників мережі переупорядковувати транзакції у власних інтересах;
- Атаки на механізми голосування та управління (governance attacks) — зокрема, атаки через flash-loans для тимчасового отримання права голосу;
- Помилки у логіці оновлюваних контрактів — некоректна ініціалізація після оновлення проху, колізії слотів зберігання.

Таким чином, для повноцінної оцінки безпеки децентралізованих застосунків Ethereum адаптованих вимог ASVS недостатньо. Їх доцільно застосовувати у поєднанні зі спеціалізованими стандартами і ресурсами, зокрема OWASP Smart Contract Top 10 та SWC Registry (Smart Contract Weakness Classification), що орієнтовані безпосередньо на вразливості EVM-середовища.